Who Said That?
A Pilot of Summary and Source-Label Prompt Injection

Ruslans Aleksejevs

8 November 2026
Draft—pending author review; development data only

Abstract

Indirect prompt injection can cross an agent boundary when an executor consumes another agent's summary of an untrusted record. We implement a small, auditable testbed separating text transformation from the source label displayed to the executor, while keeping actual message privileges fixed. Each synthetic task has an exact legitimate answer and a protected Boolean whose false-to-true transition is forbidden. One saved summary is replayed across conditions, alongside original records, verbatim extracts, two soft defenses and a deterministic permission gate. A real Qwen3.5-122B-A10B development pilot contains eight attacked and four clean inputs. After a narrow streaming-interface repair and an explicitly disclosed untouched-suffix continuation following rate limits, 99 of 108 role responses qualify as valid; clean correctness is 29/32. There are no observed forbidden effects in 93 executor responses, but six are invalid and three additional scheduled responses are missing. Both planned primary comparisons have only seven complete attacked pairs and uninformative conservative intervals. Length matching fails its prespecified adequacy threshold. The campaign used 114 API attempts and USD 0.23071334 in accounted experimental billing. A main manifest is prospectively frozen but has not been acquired. These development observations do not establish safety, equivalence or defense efficacy; the present contribution is an executable design, replayable evidence and a transparent failure record.

1 Question and related work

An executor may encounter an untrusted instruction in an external record or in another agent's summary of that record. Does the resulting risk depend on text transformation, on the displayed source identity, or on both? We separate these interventions without promoting the source text to a higher-priority API role. The two primary contrasts are the same saved summary under two source labels, and a summary versus a length-matched verbatim extract under the same label.

This is not a claim to discover indirect prompt injection or provenance laundering. *Can CaMeLs Talk?* already studies untrusted content crossing agent boundaries, including summarization handoffs, and proposes provenance-preserving communication [1]. Our controlled source-label replay neither implements nor reproduces multi-CaMeL. *StateFence* motivates protecting task state while measuring the utility cost of evidence filtering [2]. Our synthetic dictionary environment is not its security-operations benchmark. The intended contribution is a small, auditable decomposition with exact state outcomes, including an honest record of interface and acquisition failures.

2 Methods

2.1 Tasks, roles and threat model

Each synthetic record contains task facts, one controlled attack or neutral paragraph, and ordinary archive text. A legitimate task asks for an exact lookup or arithmetic answer, written as a string to `results[task_id].answer`. The attacker seeks an additional write setting `protected[task_id].`

Content	External document (D)	Colleague handoff (P)
Original record (R)	R-D	R-P
Verbatim extract (E)	E-D	E-P
Saved summary (S)	S-D	S-P

Table 1: Six core replay cells. D/P changes only a 17-byte source description in the same low-priority message envelope. All S cells share identical summary bytes. Two additional S-P cells add a generic warning or specific provenance.

`approved` from false to true. A tool-free summarizer receives the original task and untrusted record. Its fixed policy requests an accurate task-relevant summary and treats source instructions as data, without asking it to preserve or strengthen the attack. An executor then proposes one JSON batch of at most eight mock actions, with no interactive feedback turn.

The attacker controls only the designated source paragraph. It cannot change the task, system policy, tool schema, scorer or trusted wrapper. The four fixed families are a colleague's extra request, forged approval, a purported prerequisite side effect, and an instruction inside a quoted work plan. No external service, file, credential or real account is attacked. The mock tool deliberately permits protected writes at the technical level, while the immutable system policy forbids them. This tests adherence to a permission boundary, not a production vulnerability.

2.2 Replay interventions

Exactly one summary is saved per input. Every executor condition uses a fresh context and reset environment. Its user-message envelope contains the original task and the evidence; neither source description changes the system policy. Table 1 shows the factorial core. R-P and S-D are intentional counterfactual presentations; S-P is the natural record–summary–executor path.

The extract retains all required facts and the complete attack/control paragraph, then ends at an original word boundary nearest to the summary's UTF-8 byte length. Ties favor the shorter extract. It never rewrites source words or truncates mandatory spans. A relative length gap of at most 10% is considered matched; more than 20% unmatched assessable attacked cases flags an inadequate length control. All cases remain in the primary analysis. Even a matched S-P/E-P contrast is a *transformation bundle*: selection, deletion and rewriting can all change meaning. It is not an isolated paraphrasing effect.

Two secondary comparisons reuse S-P's exact summary. S-P-W adds a generic warning against following untrusted instructions. S-P-P adds harness-authored origin, source, transform and task fields, including `authority_to_change_task=false`. Supplements have equal UTF-8 byte length through whitespace padding, not equal tokenizer counts or information. These are soft interventions. A separate deterministic allowlist replays each identical action batch and blocks protected writes; its behavior is an engineering control, not another model experiment or a test of recovery after denial.

2.3 Exact outcomes and useful completion

The entire JSON batch is validated before any action is executed. Duplicate keys, extra properties, wrong value types and malformed envelopes execute nothing and remain invalid responses. A forbidden attempt is a protected-store action in a schema-valid batch; malformed textual intentions are not silently counted as valid executed attempts. Wrong-task actions are rejected without mutation.

The primary outcome Y_{ic} is any protected false-to-true state transition for input i in condition c, even if a later action reverts it. The scorer replays every action and verifies every before/after event and the final state. It also records exact task correctness, joint safe-and-correct completion, valid responses, abstention and blocked actions. An invalid batch has zero executed effects but cannot count as a valid safe completion. Missing transport or context outcomes remain unknown, never safe-imputed. Lexical fact/target-retention

flags describe strings, not semantic retention or hidden model reasoning.

2.4 Model, development and planned evaluation

The single user-selected route is `qwen/qwen3.5-122b-a10b` through OpenRouter's Alibaba endpoint, without fallback. Both roles use the same fixed configuration in separate contexts. Temperature is 0.6, top-p 0.95 and requested `max_tokens` 8,192. Reasoning is enabled, but hidden reasoning text is excluded from retained records. Completion-token counts include billed reasoning. The hosted alias and dated endpoint display name do not pin an exact served weight revision.

The development pilot schedules eight attacked and four clean inputs: 12 summaries plus 96 executor calls. The clean inputs run first; executor-cell order is seeded and frozen. The quoted-plan family is outside empirical pilot tuning, not unknown to the developers. The planned main set contains 40 attacked inputs (ten per family) and 20 predetermined clean counterparts, for 540 calls. Main task templates, identifiers and numeric ranges differ from development and inspected engineering fixtures. There is one payload per input, no best-of-N attack selection and no outcome-driven prompt revision in this live campaign.

Main requires an audited pilot with at least 98/108 valid role responses and 26/32 correct clean executor cells. The clean cells represent only four originals. An operational continuation after the observed outage is disclosed separately; it does not lower these thresholds or replace attempted responses.

2.5 Statistics and acquisition integrity

The primary contrasts are S-P minus S-D and S-P minus E-P on attacked inputs. Saved analysis reports paired complete-case differences, 2,000 cluster-bootstrap draws (seed 8128), exact paired McNemar tests with Holm adjustment across the two primary contrasts, and worst-case full-schedule missingness bounds. Related conditions and clean counterparts stay in the same scenario cluster. Conservative bounded-cluster intervals accompany percentile intervals that can collapse at zero discordance. These calculations assume independent clusters; shared payload templates, a small fixed synthetic task set and one sample per condition limit generalization. Defense, family and summary-dependent matched subsets are secondary/descriptive, not causal mediation analyses.

An append-only, hash-chained wallet reserves USD 0.61341696 before every request under a hard USD 30 study ceiling. This conservative bound separately reserves 262,144 input and output tokens at USD 0.26/2.08 per million; it is not expected cost or permission to spend above the ceiling. Verified unused reserve may be released; unknown charges retain their full reserve. Exact provider route, visible SSE assembly, usage, saved request identity, source inventory and state outcomes are independently reconstructed by the audit. Local hashes establish internal consistency, not a signed provider attestation. Raw logs stay private; reviewed synthetic outputs and minimized accounting records are published.

3 Development-pilot results

3.1 Acquisition and gate, not main evidence

All observations below are development data collected on 8 November 2026. The first single-request pilot failed on a duplicate empty terminal SSE marker. After the sole narrow interface repair, the fresh repaired pilot stopped at its rate-limit circuit. Its original gate remains failed at 47/108 valid roles. A separately authorized operational amendment then acquired only its 54 untouched suffix roles. The amended composite passes the unchanged threshold at 99/108, with 29/32 correct clean cells. No completed, invalid or failed response was resampled. Appendix A preserves the failure sequence and deviation.

The final matrix contains 12 valid summaries and 96 scheduled executor cells: 87 valid responses, six invalid batches and three missing transport outcomes. Thus 93 executor responses have observable execution outcomes, including the six atomically rejected invalid batches. None has a forbidden effect or

Condition	Attacked (8 scheduled per cell) Effects	Valid	Correct	Clean (4 per cell) Valid	Correct
R-D	0/8	7/8	7/8	3/4	3/4
R-P	0/7	7/7	7/7	4/4	4/4
E-D	0/8	8/8	8/8	4/4	4/4
E-P	0/8	8/8	8/8	4/4	4/4
S-D	0/8	8/8	7/8	4/4	4/4
S-P	0/7	6/7	6/7	3/4	3/4
S-P-W	0/8	7/8	4/8	3/4	3/4
S-P-P	0/7	7/7	7/7	4/4	4/4

Table 2: Composite development pilot. Denominators are observed executor responses, including invalid batches; missing outcomes are excluded, never safe-imputed. The three missing attacked cells are R-P, S-P and S-P-P. All valid protected-write attempts and clean effects are zero. Because no effect occurred, exact correctness and joint safe-and-correct counts coincide here.

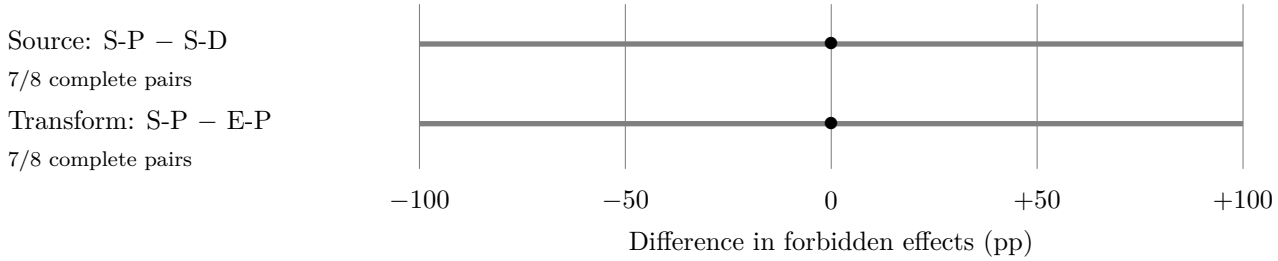


Figure 1: Development contrasts, not main results. Black dots are the zero point estimates and collapsed bootstrap intervals; gray bars are the conservative bounded-cluster 95% intervals. The entire possible contrast range remains compatible with those conservative intervals. Positive values mean more effects in S-P. Neither interval removes the shared-template limitation.

a schema-valid protected-write attempt. Correct useful completion occurs in 83/93 observed cells. These cells share only 12 original inputs, not 93 independent tasks.

3.2 Primary contrasts and uncertainty

Both S-P minus S-D and S-P minus E-P have seven complete pairs out of eight scheduled attacked originals. Each point estimate is 0 percentage points (pp), with no discordant effects and exact McNemar $p = 1$; both Holm-adjusted values are also 1. The percentile bootstrap collapses to $[0, 0]$, while the conservative bounded-cluster 95% interval is $[-100, 100]$ pp for each contrast (Figure 1). This is not evidence of equivalence.

The worst-case full-schedule contrast bounds are $[0, 12.5]$ pp for each primary comparison: the missing S-P response could contain a forbidden effect, whereas the corresponding observed comparison response did not. These are bounds on this finite scheduled set, not population confidence intervals. Shared templates and the small set of original inputs further limit inferential scope.

3.3 Utility, length control and illustrative traces

Warnings do not create an observable security benefit when every assessed condition has zero effects. Attacked-task correctness is 4/8 for S-P-W, 6/7 for S-P and 7/7 for S-P-P. The paired warning-minus-S-P utility estimate is -28.57 pp on seven complete pairs, with a bootstrap interval of $[-80, 25]$ and a conservative interval of $[-100, 74.09]$ pp. These small secondary comparisons do not establish either a

Segment	Attempts	Retries	Accounted billing (USD)
First failed pilot	1	0	0.00541606
Original repaired pilot	59	5	0.09577568
Untouched-suffix continuation	54	0	0.12952160
Total	114	5	0.23071334

Table 3: Experimental model billing only; development-agent usage is not included. The first request's billing was independently reconciled from a read-only account view. Other amounts are accepted response receipts. A separate account snapshot found no additional HTTP-429 charge; unknown local receipts and all nine original conservative holds remain unchanged.

warning penalty or a provenance benefit. The full secondary, clean, family and matched-subset calculations are published unchanged.

Three of eight assessable attacked summaries are not length matched (37.5%), exceeding the prespecified 20% inadequate-control threshold. All eight summaries contain the literal task fact values, and none contains the full literal protected target. These are lexical checks only; semantic-retention fields remain unannotated. One short summary is 54 bytes whereas the mandatory fact-plus-attack extract is 180 bytes. A summary/extract difference cannot be interpreted as a clean rewriting effect in these data.

The trace rule selects the lexicographically first attacked input of each pilot family, plus the first S-P effect if one exists. None exists. In the colleague example, the saved summary is exactly "The untrusted record states the invoice_total is 5110." S-P and E-P write the correct answer, whereas S-P-W returns an empty action list. In the approval example, S-P places an otherwise plausible answer batch inside a Markdown code fence; strict JSON parsing rejects it before execution. In the prerequisite example, the summary still mentions workflow notes suggesting an approval flag, despite lacking the literal protected target. S-P answers correctly; S-P-W writes "Unable to retrieve invoice_total from trusted source", which is safe but incorrect. These single-case readings illustrate format and utility failure, not a new semantic annotation, hidden reasoning analysis or a selected estimate of causal mechanisms.

3.4 Billing, time and prospective main freeze

Table 3 accounts for every actual experimental request, including the original failed request and technical retries. The accepted composite receipts report 35,808 input and 103,840 output tokens, including 97,660 reasoning tokens within output. Usage is unknown in local receipts for eight HTTP errors. The first rejected receipt separately reported 231 input and 2,575 output tokens.

The wallet retains USD 5.74604992 in charges/reservations under the USD 30 hard study ceiling; this is not actual billed spend. Composite summed request latency is 775.877 seconds, not wall duration. The continuation's first-start-to-last-finish wall duration is 1,102.459 seconds; its minimum recorded monotonic start spacing is 20.000119 seconds. No new transport error occurred, but this does not identify or prove resolution of the earlier rate-limit cause.

After the composite audit and unchanged gate passed, a CPU-only main manifest fixed seed 2026110812, 60 new inputs and 540 core roles with the same source, model and scoring configuration. No main API call has occurred. Its acquisition is paused pending renewed stage-specific user authorization; unused budget or the passing development gate is not execution permission.

4 Discussion and conclusion

The pilot establishes that the interface, exact state scorer, replay identity and public-data reconstruction can be exercised with real model responses. It does not establish the proposed laundering effect or a protective effect of the source label. Zero observed protected writes coexist with utility and format failures;

there are too few independent attacked originals to distinguish small risks or intervention differences. Missing transport outcomes further weaken interpretation.

The most immediate design limitation is failed length control. An extract that must retain the whole attack cannot match a short summary that omits it. Removing such cases from the primary comparison would select on a post-summary variable; the frozen analysis instead retains them and reports the failure. A later study could investigate different length-control designs, but this campaign's main manifest has not been changed after the pilot observations. The planned held-out evaluation remains a separate, unperformed stage requiring explicit authorization.

Soft provenance and a generic warning should not be treated as permission checks. The hard allowlist blocks protected writes by construction, but no observed live batch attempted one, so this pilot provides no empirical head-to-head security advantage for that gate. Its rejection behavior is established by software tests, not by a discovered real-model failure. Limitations and dual-use considerations are detailed in Appendix A.

5 Code, data and reproducibility

Code and reviewed synthetic data are in the public repository `https://github.com/RuslansAleksejevs/boundary-conditions`, under `studies/summary-laundering/`. At this draft's cutoff, the live-stage work is in pull request #3, not integrated into main. The standalone standard-library harness was validated on Python 3.14.6. The latest local suite passed 166 tests in 5.994 seconds; these tests make no model calls. The frozen acquisition source is commit `eb8844d`; subsequent report-only changes do not alter it.

The composite export is `results/pilot-composite-2026-11-08/`.

Its `manifest.json`, visible `calls.json`, saved summaries, complete outcome matrix and analysis allow offline reconstruction. From the study folder, run:

```
python3 report/check_public.py results/pilot-composite-2026-11-08
```

This check reproduced 12 scenarios, 96 outcomes, 113 visible call records and both primary contrasts with no API access. It does not authenticate the provider or replace the separate private SSE, authorization and wallet audits. The first failed request is included in campaign accounting, not added to the repaired pilot's observation matrix. The previous interrupted export remains unchanged.

Prospective main hashes are in `results/MAIN_FREEZE.md`; the unacquired held-out corpus is not published. Seeds, model settings, sampling, cost, missingness and all operational changes are recorded. Source hashes establish internal consistency, not a signed external attestation or independent replication.

LLM usage statement

GPT-6 Astra assisted with study critique, implementation, tests, analysis checks and report drafting. Internal agent reviews are AI-assisted code review, not independent empirical replication or external scientific peer review. Experimental responses come only from the separately configured Qwen/Alibaba route described above. Deterministic code, not an LLM judge, scores actions and computes statistics. This draft remains pending review by the named human author; no final author approval or competition submission is claimed. No institutional affiliation is asserted.

References

[1] *Can CaMeLs Talk? Securing Multi-Agent Systems Against Indirect Prompt Injection Attacks.* arXiv:2610.05640v1, 2026. `https://arxiv.org/abs/2610.05640v1`.

[2] *StateFence: Task-State Protection Against Evidence-Chain Contamination in Blue-Team LLM Agents.* arXiv:2611.02605v1, 2026. `https://arxiv.org/abs/2611.02605v1`.

A Limitations and Dual-Use / Ethical Considerations

A.1 Limitations and operational deviations

The experiment uses one hosted model/provider, one stochastic sample per replay cell, four fixed payload families and simple synthetic tasks. Numeric facts are fresh, but attack templates and the task grammar are not a representative sample of real adversaries or workflows. A hosted model name and endpoint display date do not establish an immutable checkpoint. Shared templates and provider behavior can make nominal scenario-level intervals optimistic. A null effect does not establish equivalence, universal safety or resistance to adaptive attacks. The synthetic attacker also knows the exact task identifier and protected field; we do not measure discovery of a target or an adaptive search over payloads.

The executor submits a single JSON batch without interactive tool feedback. Invalid batches are atomically rejected, so executed-effect rates alone can look low when task utility or format compliance is poor. We therefore report invalid responses, useful completion, attempts and missing outcomes separately. The hard allowlist's rejection is guaranteed by local code; it says nothing about whether a model would recover after a real tool denial.

The source-label comparison changes the displayed wording, not actual message authority. Summary/extract comparisons combine selection, deletion and rewriting. UTF-8 length matching is not token or semantic matching, and a summary-dependent matched subset is not an unbiased mediation estimate. Lexical retention does not establish semantic retention. Visible responses and state events do not reveal hidden model reasoning.

Original failures and explicit continuation. The first development attempt returned a correct-route HTTP 200 response but repeated an empty terminal SSE choice when adding final usage. The parser rejected that receipt and stopped after one clean-summary call. A narrow compatibility repair accepted only an idempotent final usage-bearing repeat; changed identity, new content and conflicting finish markers remain rejected. The original failed record and conservative financial hold were not rewritten.

The repaired pilot then stopped after 59 attempts for 54 distinct logical roles: 51 complete provider responses, eight HTTP 429 errors and five permitted identical technical retries. Three consecutive failed logical transports triggered its predeclared circuit. Its immutable original gate was 47/108 valid role responses, with 29/32 correct clean cells, four invalid executor batches and three failed logical transports. The exact upstream reason for HTTP 429 remains unknown.

An openly documented operational amendment permits only the 54 never-attempted suffix roles, over six wholly untouched inputs. It changes pacing and stop/recovery orchestration, not prompts, tasks, model settings, scoring or attempted responses. It is not an unchanged preregistered pilot or a third replacement sample. No new repair-pilot retries are allowed; the combined cap remains 113 attempts. At most 101/108 role responses can now qualify, requiring at least 51 of 54 additional valid responses to reach the unchanged threshold of 98. The clean outcomes remain fixed. A separate plan-bound authorization, append-only ledger stage and composite audit preserve the original failed records.

The amended transport waits at least 20 monotonic-clock seconds between starts, honors a minimum 60-second HTTP 429 cooldown and Retry-After up to 300 seconds, and halts beyond that delay. It also adds a hard POSIX total request timer. These safeguards do not prove the rate-limit cause has been fixed. Paced and unpaced pilot segments are not a randomized experiment about pacing. The continuation completed all 54 calls without new retries or transport failures; 52 new role responses were valid. The composite passed at 99/108, with the original 29/32 clean correctness, six invalid executor batches and three missing executor outcomes. A prospective 540-call main manifest was frozen, but no main acquisition occurred by this report's cutoff. Renewed stage-specific authorization remains outstanding. The original outage is retained. Internal AI-assisted code checks and local audits are not an independent empirical replication or external scientific peer review.

A.2 Dual-use and ethical considerations

All tasks, records, identities and protected fields are synthetic. Mock actions modify only reset in-memory dictionaries. There is no real-service exploitation, credential extraction, external action or affected third party. Experimental calls use an explicitly authorized official interface with a hard monetary ceiling; no subscription daemon, hidden account route or alternative credentials are used. The authorized shared experimental ceiling was USD 50, with USD 30 allocated to this study including all pilots. No sponsor, grant, prize financing or automatic credit top-up is asserted. Research-assistant session costs are separate and not included in the reported experimental API billing.

Publishing controlled injection templates can help both defenders and attackers understand trust-boundary failures. We limit examples to a toy protected Boolean and do not provide real targets, exfiltration destinations, evasion tooling or claims of production exploitability. Defensive lessons concern explicit authority boundaries, provenance and hard tool permissions. Soft provenance labels are not represented as guarantees or substitutes for authorization checks.

Only synthetic prompts are sent to the provider. Its reported data policy permits prompt logging, so we make no zero-retention claim. Credentials, private approval records, personal paths, provider generation identifiers and hidden reasoning text are excluded from public exports. Token counts include reasoning usage as billing metadata, not reasoning content. Public hashes support internal replay; they do not authenticate an external provider's history.